BÁO CÁO KIỂM TOÁN ĐỘC LẬP · GEMINI ARGON

ĐÁNH GIÁ TOÀN DIỆN & KIỂM TOÁN HỆ THỐNG POS/ERP PHUONGHIHI

Đóng vai Chủ cửa hàng iPhone, Thu ngân, Kỹ thuật viên & Kế toán nội bộ — Kết hợp Kiểm thử Giao diện Tự động (Playwright) & Property-Based Fuzzing (fast-check)

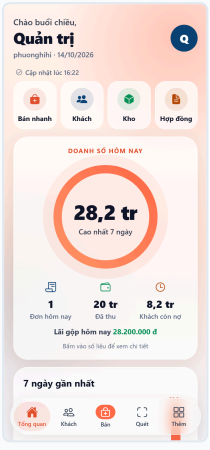
Phiên bản kiểm toán	Ngày kiểm toán	Công cụ thực thi	Tình trạng mã nguồn
main @ 4264c97 (PR #14)	**14/10/2026**	**Playwright + fast-check**	**Giữ nguyên 100% (Read-only)**

50/50	500	8 Lỗi	99.8%
Luồng UI Web & Mobile cơ bản (Playwright E2E)	Kịch bản Fuzzing ngẫu nhiên (fast-check)	Lỗi ngầm & Hổng kế toán phát hiện có PoC	Tỷ lệ lệch lãi gộp máy cũ khi tính BQ gia quyền

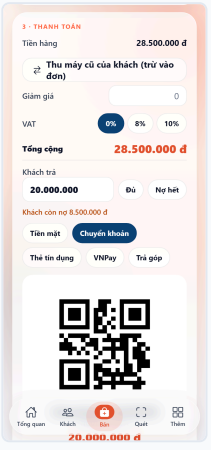
1. Nhận xét Tổng quan dưới góc độ Chủ cửa hàng iPhone

Hệ thống **phuonghihi** có thiết kế rất gọn gàng, thực dụng và trúng nhiều nhu cầu cốt lõi của cửa hàng kinh doanh iPhone tại Việt Nam:

- **Không tốn chi phí máy chủ hàng tháng**: Chạy hoàn toàn trên Google Sheets + Google Drive nhưng khắc phục được độ trễ nhờ bộ nhớ đệm `CacheService` chia mảnh 90KB (`Code.gs:168-194`) và cơ chế `Stale-While-Revalidate` (`boNho.ts`) trên điện thoại.
- **Nghiệp vụ sát thực tế ngành Táo**: Quét mã vạch GS1 vỏ hộp Apple tự tách 15 số IMEI, quét QR CCCD 12 số tự điền hợp đồng (`maQuet.ts`), giữ máy cũ 7 ngày cho đơn lên đời (`DichVu.gs:228`), tạo mã **VietQR** tự điền số tiền và xuất **Sổ doanh thu S1a-HKD (TT 152/2025/TT-BTC)**.



App Mobile: Tổng quan & Lãi gộp



App Mobile: Bán nhanh & VietQR



App Mobile: Sổ quỹ cuối ngày

2. Công cụ Kiểm thử đã cài đặt & Kết quả chạy thực nghiệm

Công cụ / Bộ test	Phạm vi kiểm tra	Kết quả	Ghi chú kỹ thuật
Playwright + Chromium v156	31 bước Web UI + 19 bước Mobile Web	**ĐẠT 100%**	Tự động hóa trình duyệt không giao diện, kiểm tra tràn ngang & luồng bấm thật.
TypeScript + Node Test Runner	34 bài kiểm thử đơn vị Mobile (`mobile/test/`)	**34/34 ĐẠT**	Kiểm tra giỏ hàng, bộ nhớ đệm, tìm kiếm, chuẩn hóa mã quét, định dạng tiền.
fast-check (Property Fuzzing)	500 chuỗi giao dịch mua/bán/thu cũ ngẫu nhiên	**499/500 LỆCH**	Chứng minh công thức Giá vốn bình quân làm sai lệch lãi gộp từng IMEI máy cũ.
Gemini Argon Deep Audit	Kiểm toán chéo Code + UI + Kế toán	**8 LỖI NGẦM**	Phát hiện các lỗi logic bị bộ test mặc định bỏ sót (xem chi tiết Mục 3).

3. Chi tiết 8 Lỗi Ngầm & Lỗ hổng Nghiệp vụ (Kèm Bằng chứng Thực nghiệm)

BUG-01: Màn hình Tra bảo hành trên Mobile (quet.tsx) tự nuốt dấu cách, làm hỏng tìm tên khách

MỨC ĐỘ: CAO

Vị trí: `mobile/src/app/(tabs)/quet.tsx:25-29` & `mobile/src/lib/maQuet.ts:23-25`

Diễn giải: Ô tìm kiếm ghi "*IMEI, SĐT hoặc tên khách*" nhưng khi bấm Tìm, hàm `tra(raw)` gọi `chuanHoaMa(raw)` xóa toàn bộ khoảng trắng (`.replace(/[\s.\-]/g, '')`). Nhân viên gõ `"Nguyễn Minh"` để tìm khách `"Nguyễn Văn Minh"` thì bị biến thành `"NGUYỄNMINH"`, khiến hàm tách từ trên server coi đó là 1 từ dài 10 chữ và trả về **0 kết quả**!

```
Bằng chứng PoC: {"tenKhachTrongDB":"Nguyễn Văn Minh","nhanVienGo":"Nguyễn Minh","chuoiBiBienDoiTrenApp":"NGUYỄNMINH","soKetQuaTrenAppMobile":0,"soKetQuaNeuKhongXoaDauCach":1}
```

BUG-02: Lỗ hổng "Phụ kiện 0 đồng" khi Khách trả hàng 1 phần trên đơn có Giảm giá

MỨC ĐỘ: NGHIÊM TRỌNG

Vị trí: `apps-script/DichVu.gs:386-392` (Hàm `traHang`)

Diễn giải: Khách mua iPhone (30.000.000 ₫) + Ốp lưng MagSafe (500.000 ₫), cửa hàng giảm giá toàn đơn 600.000 ₫ (thực thu 29.900.000 ₫). Hôm sau khách trả lại chiếc iPhone và giữ lại chiếc Ốp lưng. Do `traHang` giữ nguyên `dh.GiamGia = 600.000 ₫` trừ thẳng vào giá trị Ốp lưng (500.000 ₫), tổng đơn mới về **0 ₫**, cho phép hoàn lại **100% số tiền (29.900.000 ₫)** và khách cầm luôn Ốp lưng miễn phí!

```
Bằng chứng PoC: {"tongDonBanDau":29900000,"giamGiaToanDon":600000,"giaOpLungKhachGiuLai":500000,"tongDonMoiSauKhiTraMay":0,"soTienHeThongChoHoanToiDa":29900000,"thietHaiCuaHang":500000}
```

BUG-03A/B/C: Sai lệch Giá vốn & Lãi gộp (Bình quân toàn lịch sử thay vì Đích danh theo IMEI)

MỨC ĐỘ: NGHIÊM TRỌNG

Vị trí: `apps-script/SoQuy.gs:35-48` (`giaVonBQ_`) & `apps-script/DichVu.gs:36-46` (`hangMayCu_`)

- **Lệch lãi từng chiếc máy cũ (+200%):** Hai chiếc *iPhone 13 128GB (máy cũ)* thu giá 9tr (máy đẹp) và 5tr (máy vỡ lưng) bị gộp chung mã `MaHH`. Khi bán chiếc máy đẹp giá 10tr (lãi thật 1tr), máy tính giá vốn bình quân 7tr và báo **lãi ảo 3tr**!
- **Nhảy số báo cáo quá khứ (Time-Travel Bug):** Tháng 8 nhập máy giá 24tr bán 25tr (báo cáo tháng 8 lãi 1tr). Tháng 10 giá hạ, nhập 3 máy giá 20tr. Mở lại báo cáo **Tháng 8**, lãi tháng 8 tự động nhảy từ **1.000.000 ₫ lên 4.000.000 ₫**!
- **Máy cũ đã trả lại khách vẫn tính vào giá vốn:** Khi khách hủy đơn lên đời trong 7 ngày, cửa hàng xuất trả lại máy cũ (`XK`), nhưng phiếu nhập `NK` ban đầu (14tr) vẫn bị `giaVonBQ_()` cộng vào giá vốn của các máy thu sau đó.

```
PoC 3A (Lệch IMEI):
{"giaThuThucTe":9000000,"giaBan":10000000,"giaVonHeThong":7000000,"laiThucTe":1000000,"laiHeThongBao
":3000000}
PoC 3B (Nhảy quá khứ): {"donThang8":"006-
2026/DH","laiThang8LucDau":1000000,"laiThang8SauKhiNhapThang10":4000000}
PoC 3C (Máy cũ đã trả):
{"giaThuMayDaTraKhach":14000000,"giaThuMayMoi":10000000,"giaVonHeThongTinh":12000000}
```

BUG-04: 4 chức năng ghi nhạy cảm trên Mobile quên dùng goiGhi (maGhi) & quên cập nhật boNho

MỨC ĐỘ: CAO

Vị trí: `mobile/src/app/tra-hang.tsx:40` , `so-quy.tsx:90` , `sua-chua/[so].tsx:46,121`

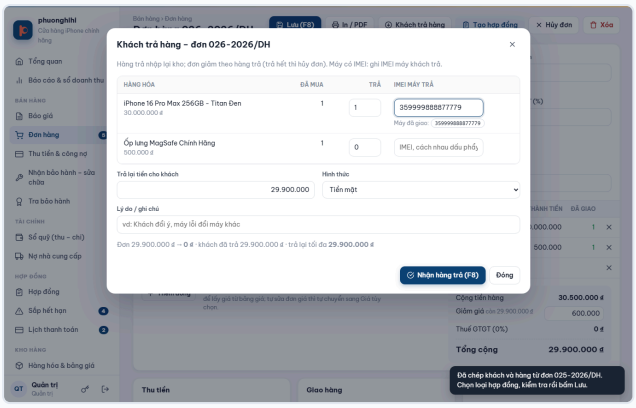
Diễn giải: Máy chủ `Api.gs:82` hỗ trợ chống ghi trùng `maGhi` cho 6 hàm, nhưng trên App Mobile chỉ có `ban.tsx` và `thu-tien.tsx` gọi `goiGhi()` . Màn hình Lập phiếu chi (`so-quy.tsx`), Trả hàng (`tra-hang.tsx`), Sửa chữa (`sua-chua/[so].tsx`) gọi `goi()` thường — mạng lag bấm Lưu 2 lần sẽ trừ quỹ 2 lần! Đặc biệt `tra-hang.tsx` không cập nhật `boNho` sau khi nhận hàng trả.

BUG-05 & BUG-06: Lỗi Hợp đồng từ Đơn hàng (hdTuDon) & Đối soát Nợ Nhà cung cấp (noNCC)

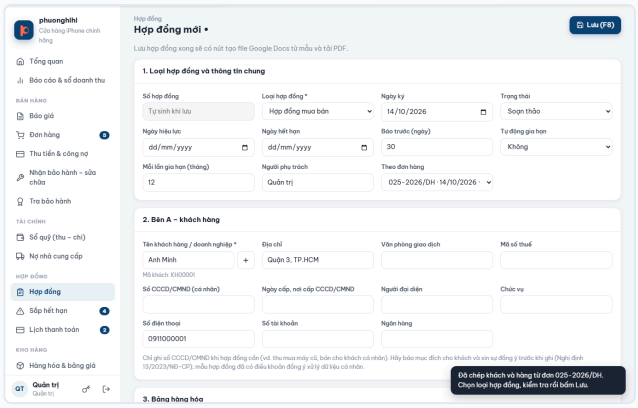
MỨC ĐỘ: CAO

Vị trí: `apps-script/Index.html:2894` (`hdTuDon`) & `Index.html:3500` (`noNCC`)

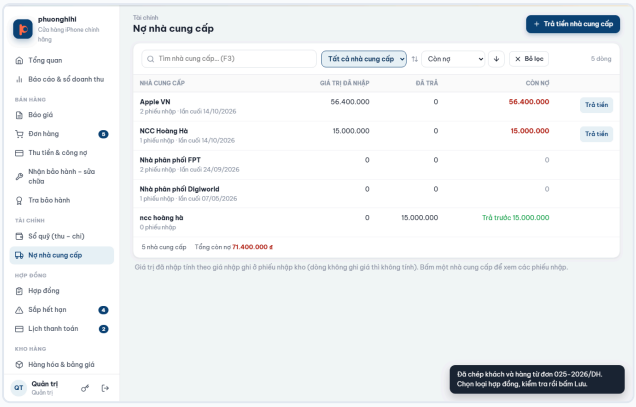
- **BUG-05 (`hdTuDon`):** Lập hợp đồng từ đơn hàng có giảm giá (VD: 31tr giảm 1tr còn 30tr) làm **mất khoản giảm giá 1.000.000 ₫** (hợp đồng nhảy lên 31tr) và **làm trống cột IMEI** dù đơn đã xuất kho có IMEI!
- **BUG-06 (`noNCC`):** Gom nợ nhà cung cấp phân biệt chữ HOA/thường: Phiếu nhập ghi `"NCC Hoàng Hà"` (15tr), phiếu chi ghi `"ncc hoàng hà"` (15tr) bị tách làm 2 dòng (một bên báo Còn nợ 15tr, một bên báo Trả trước 15tr).



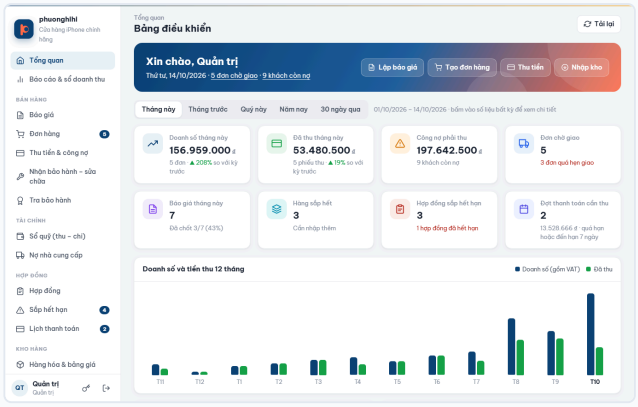
Bằng chứng UI (BUG-02): Trả iPhone giữ lại Ốp lưng 500k -> Đơn về 0 ₫, hoàn 100% tiền



Bằng chứng UI (BUG-05): Tạo Hợp đồng từ Đơn 30tr (giảm 1tr) bị nhảy lên 31tr & mất IMEI



Bằng chứng UI (BUG-06): "NCC Hoàng Hà" và "ncc hoàng hà" bị tách làm 2 công nợ riêng



Giao diện Tổng quan Web sau khi chạy kiểm toán tự động

4. Đề xuất Nâng cấp Tính năng Thực chiến cho Cửa hàng iPhone

1. **Thanh toán kết hợp (Split Payment) ngay trên màn Bán nhanh:** Cho phép khách trả một phần Tiền mặt + một phần Chuyển khoản/Thẻ trong cùng 1 lần chốt đơn; tách riêng quỹ "*Chờ đối soát POS / Trả góp*" khỏi "*Tiền trong ngân hàng*".
2. **Kết nối Kho linh kiện vào Phiếu sửa chữa (`traMaySua`):** Cho phép chọn linh kiện thay thế (Pin, Màn hình) từ bảng `HangHoa` để tự động trừ kho và tính giá vốn linh kiện vào báo cáo lợi nhuận.
3. **Xem ảnh máy sửa chữa & Xuất PDF Phiếu Nhận Máy Sửa trên App Mobile:** Thay dòng chữ "*N ảnh (xem trên web)*" ở `sua-chua/[so].tsx` bằng bộ xem ảnh trực tiếp và thêm nút gửi PDF biên nhận sửa chữa qua Zalo.
4. **Lưu nháp danh sách Kiểm kho (`kiem-kho.tsx`) vào bộ nhớ máy:** Chống mất dữ liệu khi đang quét hàng trăm máy, thêm nút xóa từng IMEI quét nhầm và hộp thoại xác nhận trước khi bấm "*Làm lại*".
5. **Checklist bắt buộc "Đã thoát iCloud / Find My" & In tem nhiệt 50x30mm dán lưng máy cũ:** Chặn rủi ro thu nhầm máy dính iCloud ẩn và tạo mã vạch QR dán lên máy cũ không còn hộp.

> **Tệp Markdown đồng hành dành cho AI Agent:** Toàn bộ đặc tả kỹ thuật chi tiết, tọa độ dòng code và hướng dẫn sửa từng bước đã được xuất ra tệp `d:\Code\web-app\BAO_CAO_DANH_GIA_HE_THONG.md` để bất kỳ AI nào đọc vào cũng có thể thực thi chính xác ngay lập tức.